

Audit technique — Qualité de code & dette

Développeur / Lead technique

Projet	CleanUx / brio — marketplace multi-métiers (Laravel 12 + apps mobiles Expo)
Destinataire	Développeur / Lead technique
Date d'audit	24 juin 2026
Référence	Réactualisation de l'audit plateforme du 8 juin 2026
Confidentialité	Document interne — confidentiel

Légende sévérité : ● Critique · ● Élevé · ● Moyen · ● Faible · ● Sain / Corrigé

1. Résumé exécutif

Le projet est une base de code **vaste, dense et techniquement crédible** : ~1 209 fichiers PHP dans `app/` , ~353 fichiers de services répartis en ~80 domaines, 204 migrations, ~660 fichiers de test. L'architecture suit proprement les conventions Laravel (Services, Actions, Jobs, Events, Politiques, Livewire) et l'outillage qualité est en place et globalement bloquant en CI (Pint, PHPStan, ESLint/Prettier, Husky, couverture ≥ 80 %).

Bonne nouvelle majeure : les findings **Critiques et Élevés** de l'audit du 8 juin 2026 sont **corrigés** dans le code actuel (vérifié ligne à ligne) — double payout Stripe, idempotence des virements, garde anti-double-annulation, IDOR module Qualité, cron RGPD, flow QR mobile. Les correctifs sont sérieux et **tracés** (commentaires de code référençant les IDs de findings, 81 commits depuis l'audit).

Ce qui reste à traiter, côté développeur, est de la **dette structurelle** plutôt que des bugs bloquants : une baseline PHPStan colossale (~3 355 erreurs gelées), la coexistence v2/legacy non finalisée, un schéma stabilisé par 19 migrations « fix/round », et une suite de tests dont les chiffres affichés ne sont pas fiables. À cela s'ajoutent des **incohérences de documentation** (nom du produit, version de Laravel) qui nuisent à la confiance.

Verdict développeur : socle sain et bien outillé, risques critiques résorbés. La priorité n'est plus le « réparer du cassé » mais le **désendettement** (baseline PHPStan, suppression du legacy, fiabilisation des tests) avant d'accélérer sur de nouvelles fonctionnalités.

2. Métriques mesurées

Indicateur	Valeur mesurée	Source
Fichiers PHP dans <code>app/</code>	1 209	<code>find app -name "*.php"</code>
Fichiers de services	353 (~80 domaines)	<code>app/Services/**</code>
Migrations	204 (dont 19 « fix/round »)	<code>database/migrations</code>
Fichiers de test	660	<code>find tests</code>
Baseline PHPStan	18 781 lignes / ~3 355 erreurs ignorées	<code>phpstan-baseline.neon</code>

Indicateur	Valeur mesurée	Source
Niveau PHPStan	level 6	phpstan.neon:8
Laravel réellement installé	v12.62.0	composer.lock
Fichiers > 500 lignes dans app/	6 seulement	mesuré

3. Constats — Qualité & dette

3.1 Baseline PHPStan massive : ~3 355 erreurs gelées

phpstan-baseline.neon fait **18 781 lignes** pour ~3 355 erreurs ignorées, avec `reportUnmatchedIgnoredErrors: false` (phpstan.neon:13) et une suppression globale `Call to an undefined method ... Eloquent\Builder` (phpstan.neon:15).

- **Impact dev** : le « PHPStan L6 vert » est trompeur — c'est ~3 355 erreurs gelées. La suppression globale masque de vraies erreurs de typage Eloquent partout, et le baseline peut diverger silencieusement du code.
- **Recommandation** : fixer un budget décroissant de baseline en CI (objectif : -X entrées/sprint) ; remplacer la suppression globale par des annotations `@method` /generics ciblées.

3.2 Coexistence v2 / legacy persistante

Plusieurs domaines ont deux implémentations physiquement présentes :

- `Services/Cancellation` (legacy) et `Services/CancellationV2`
- `Services/Onboarding` et `Services/OnboardingV2` (+ wizard web Livewire)
- `Services/Subscription` et `Services/SubscriptionsV2`
- `Services/Pricing` et `Services/PricingV2` · `Services/Contracts` et `Services/ContractsV2`
- **Deux classes homonymes** `ProviderPresenceService` (`Services/Presence` vs `Services/Provider`)

La divergence **fonctionnelle** d'annulation a été corrigée au niveau des routes, mais le **code legacy reste présent** (ex. `CancelBookingService.php`). Risque de modifier la mauvaise implémentation.

- **Recommandation** : décider officiellement de la source de vérité par domaine, renommer les classes homonymes, supprimer le legacy non retenu.

3.3 Schéma stabilisé par patches successifs

19 migrations correctives : `... fix_portal_legacy_columns_round2`, `... fix_runtime_schema_round6`, `... fix_remaining_test_schema_compat_round_final`, etc. Colonnes ambiguës survivantes (`bookings.surface` vs `surface_m2`, `tenant_id` mort).

- **Impact** : schéma de base difficile à appréhender, divergences possibles entre SQLite (tests) et MySQL (prod).
- **Recommandation** : à terme, `schema:dump` (squash des migrations) pour repartir d'un schéma propre ; documenter les colonnes legacy/compat conservées.

3.4 Tests : chiffres non fiables & config SQLite sans FK

Le README annonce « 2116 tests verts / 6007 assertions » mais on mesure ~660 fichiers et ~4 228 méthodes — chiffres incohérents entre README (2116) et CHANGELOG (1700+). La suite par défaut tourne sur **SQLite**

:memory: avec `DB_FOREIGN_KEYS=false` (`phpunit.xml:42-44`). Le job MySQL avec FK (`money-integrity-mysql`) existe mais est **non bloquant** (`ci.yml:84`).

- **Impact** : les bugs d'intégrité référentielle ne sont pas attrapés par défaut ; « tout vert » partiellement optimiste.
- **Recommandation** : rendre le job MySQL/FK bloquant sur les suites argent/RGPD ; remplacer les chiffres marketing par une sortie CI vérifiée.

3.5 Incohérences de nommage & version (doc)

Affirmation	Réalité	Preuve
Nom « CleanUx »	Package <code>brio/marketplace</code>	<code>composer.json:2</code>
« Laravel 11.53 »	Laravel 12.62	<code>composer.lock</code>
<code>php ^8.2</code>	Patcher <code>php85</code> exécuté à chaque install	<code>composer.json:61,65,68</code>

- **Recommandation** : choisir un nom canonique, corriger le README (Laravel 12), clarifier la matrice PHP cible.

3.6 Concentration de complexité sur le flow de réservation

6 fichiers seulement dépassent 500 lignes, mais ils se concentrent sur le booking :

`Livewire/Client/PrendreRendezVous.php` (776), `Models/Booking.php` (730), plusieurs concerns booking de 500+.

- **Recommandation** : extraire la logique de `PrendreRendezVous` ; le `Booking` est un modèle gras (aliases legacy `HasLegacyBookingAliases`).

4. Statut des findings 8 juin (vérifié dans le code actuel)

Réf	Finding	Statut 24/06
A1 	Double payout Stripe (cron)	 Corrigé (<code>payout_status='auto_transferred'</code> , Phase 2 exclut les captured)
A2 	<code>Transfer::create</code> sans idempotence	 Corrigé (<code>idempotency_key</code> + <code>lockForUpdate</code>)
B1 	Booking complété ré-annulable	 Corrigé (<code>BookingStatus::nonCancellableAliases()</code>)
C1 	IDOR module Qualité	 Corrigé (<code>MissionQualityInspectionPolicy</code> + <code>authorize()</code>)
D1 	Cron erasure RGPD cassé	 Corrigé (<code>gdpr:execute-erasures</code> + test de résolabilité)
E1/E2 	Flow QR mobile cassé	 Corrigé (routes <code>qr-start/qr-end</code> + transmission du code)
F1 	Double système d'annulation	 Corrigé au niveau routes ; code legacy encore présent
M18 	Kill-switch feature flag no-op	 Corrigé (lecture des overrides DB au runtime)
H1 	Tests AI write sautés en CI	 Partiel (skip retiré ; job MySQL non bloquant)

5. Points sains confirmés

- Findings critiques argent & RGPD **corrigés et tracés** (commentaires `// A1` , `// M18` , etc.).
- Outillage qualité réel et bloquant : Pint, PHPStan L6, ESLint+Prettier, Husky/lint-staged, CI multi-jobs, couverture min 80 %, E2E Playwright par rôle.
- Helpers globaux minimalistes (~6 fonctions), peu de fichiers monstres (6/1209 > 500 lignes).
- Idempotence/verrous ajoutés sur le cron payouts ; webhooks entrants idempotents.

6. Plan d'action développeur (priorisé)

#	Action	Effort	Adresse
1	Rendre bloquant le job MySQL/FK sur suites argent/RGPD ; fiabiliser les chiffres de tests	M	3.4 / H1
2	Plan de réduction de la baseline PHPStan (budget décroissant) + retirer la suppression globale Builder	L	3.1
3	Supprimer le code legacy non retenu (Cancellation, Onboarding...), lever les classes homonymes Presence	M	3.2
4	Corriger le README (Laravel 12, nom canonique) et la matrice PHP	S	3.5
5	<code>schema:dump</code> / squash des migrations avant prod ; documenter colonnes legacy	M	3.3
6	Refactor de <code>PrendreRendezVous</code> et allègement de <code>Models/Booking</code>	M	3.6

Effort : $S \leq 1j \cdot M \leq 3j \cdot L > 3j$.

Réserve méthodologique : la suite de tests, PHPStan et Pint n'ont pas été exécutés (pas de runtime PHP lancé) ; seuls la configuration et le code ont été vérifiés. Le compte de méthodes de test (~4 228) est un grep approximatif.